



ISC 互联网安全大会



360 互联网安全中心



消费者用户与设备身份认证

李雨航

华为CBG首席安全与隐私专家，中国电子认证联盟副理事长

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

人的身份PERSONAL IDENTITY (ID)

身份ID 》信任Trust 》权益rights&benefits, 地位status, 资源resources...

空间维度：可信唯一
哪个是真正的他/她/它？

时间维度：生命周期
过去的那个是现在的这个吗？

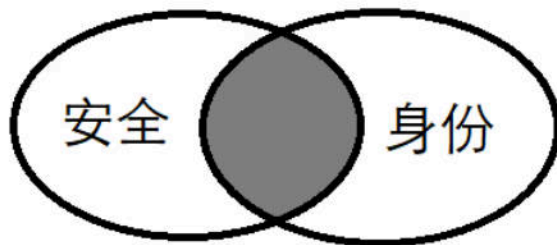


ZERO TRUST SECURITY

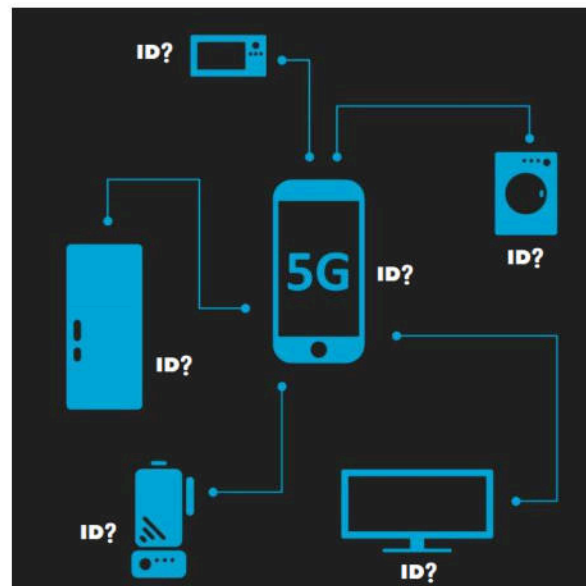
未来场景复杂化：血液更换，器官移植，生物克隆...

物理世界人的身份--》
虚拟世界的数字身份:
网络账号（人的映射）

物理世界人的身份—》
物理世界+虚拟世界物的身份:
设备ID（人的属性）



哲学, 道德,
伦理, 生物,
遗传, 政治,
法律, 心理...



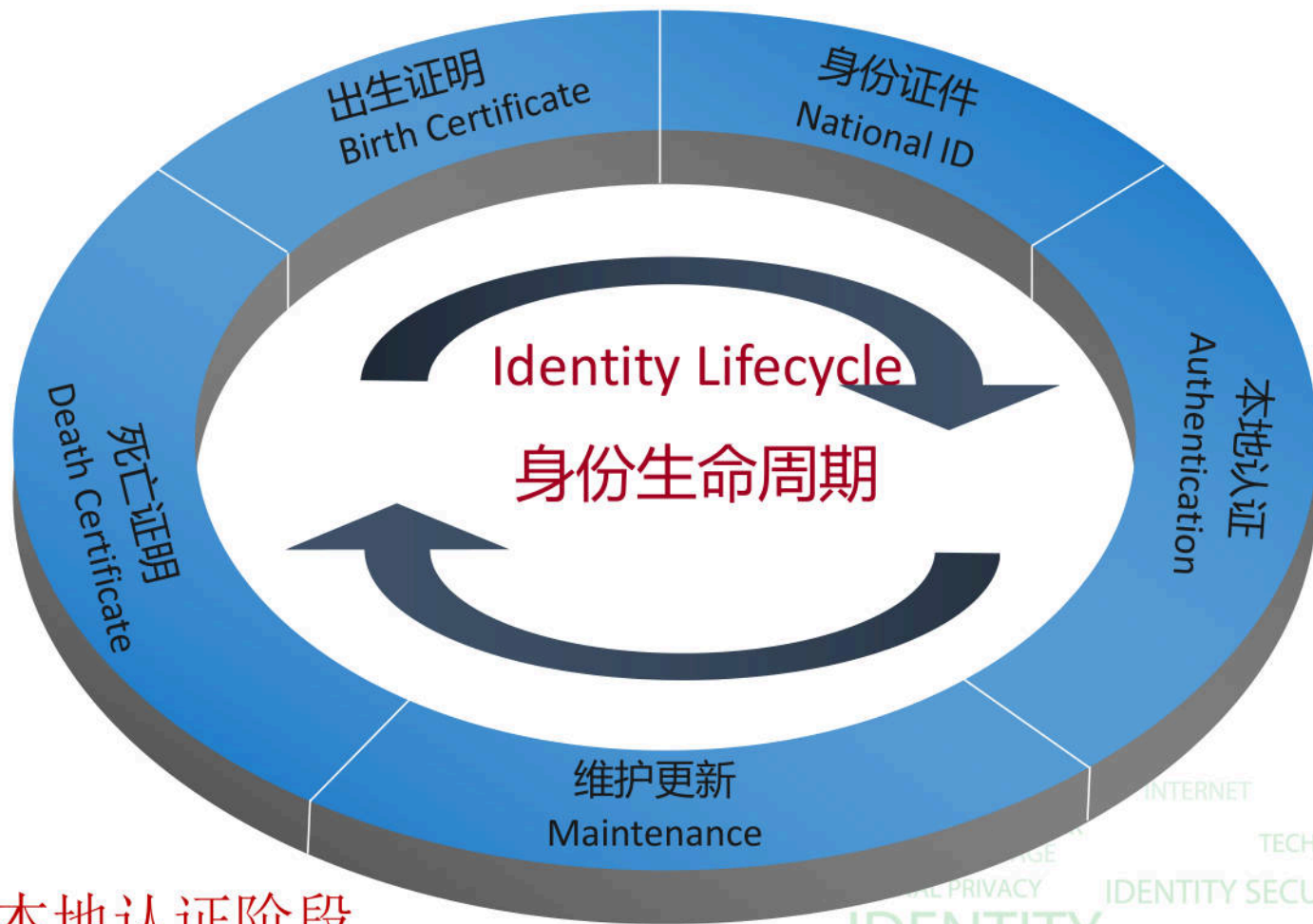
可信唯一

信任根源：本人活体+证明人

唯一标识：**DNA**等生物特征+证件
(未来：安全芯片植入人体?)

认证方法：**Pin**码，生物识别等

厂商仅负责本地认证阶段

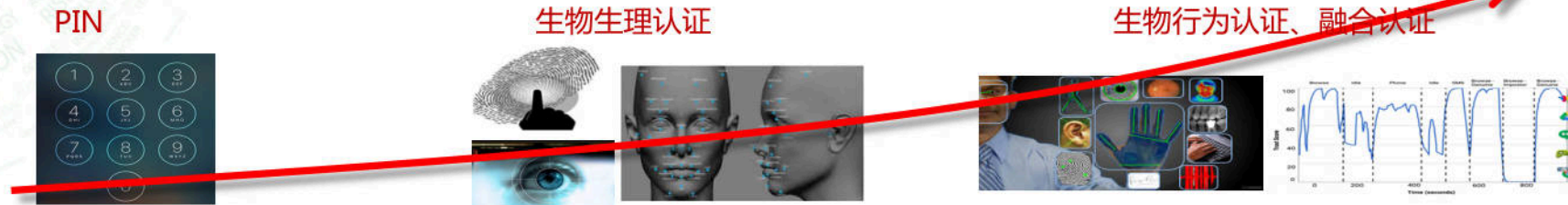


本地身份认证的技术演进趋势

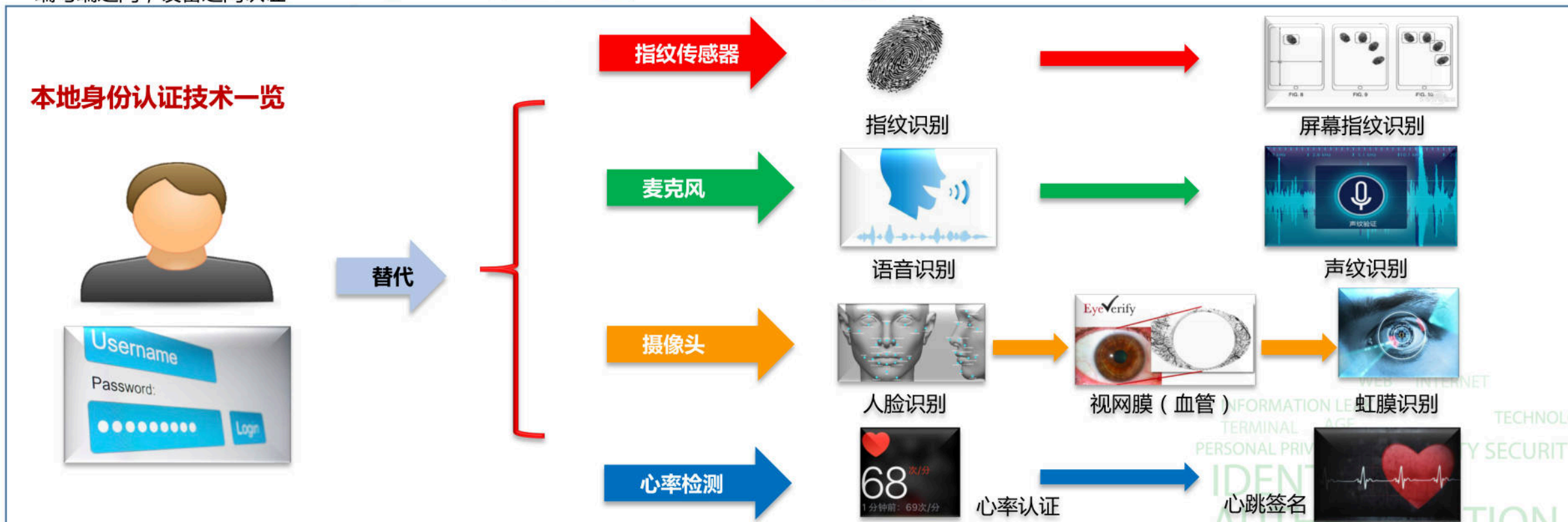
身份认证分为三类

- 1、**本地身份认证**：
基于端，对人的认证
- 2、**账号身份认证**：
端与云之间，对用户的认证
- 3、**设备身份认证**：
端与端之间，设备之间认证

本地身份认证技术演进趋势

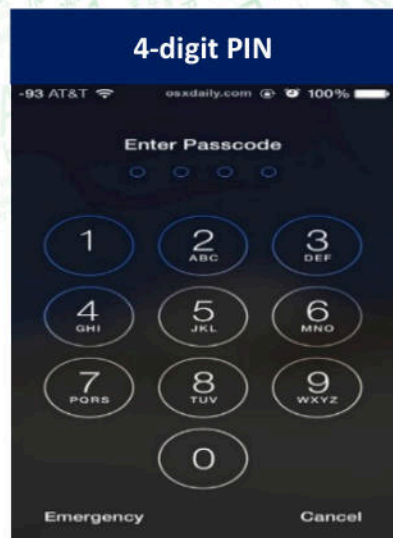


本地身份认证技术一览



行为身份认证是新一代身份认证技术

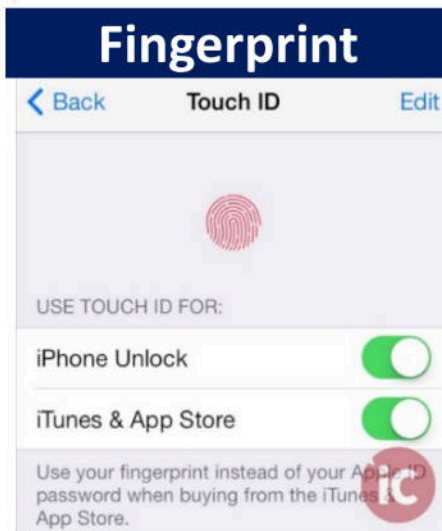
本地身份认证威胁与挑战



FAR=1:10,000



FAR=1:50,000



FAR=1:50,000



FAR=1:1,000,000



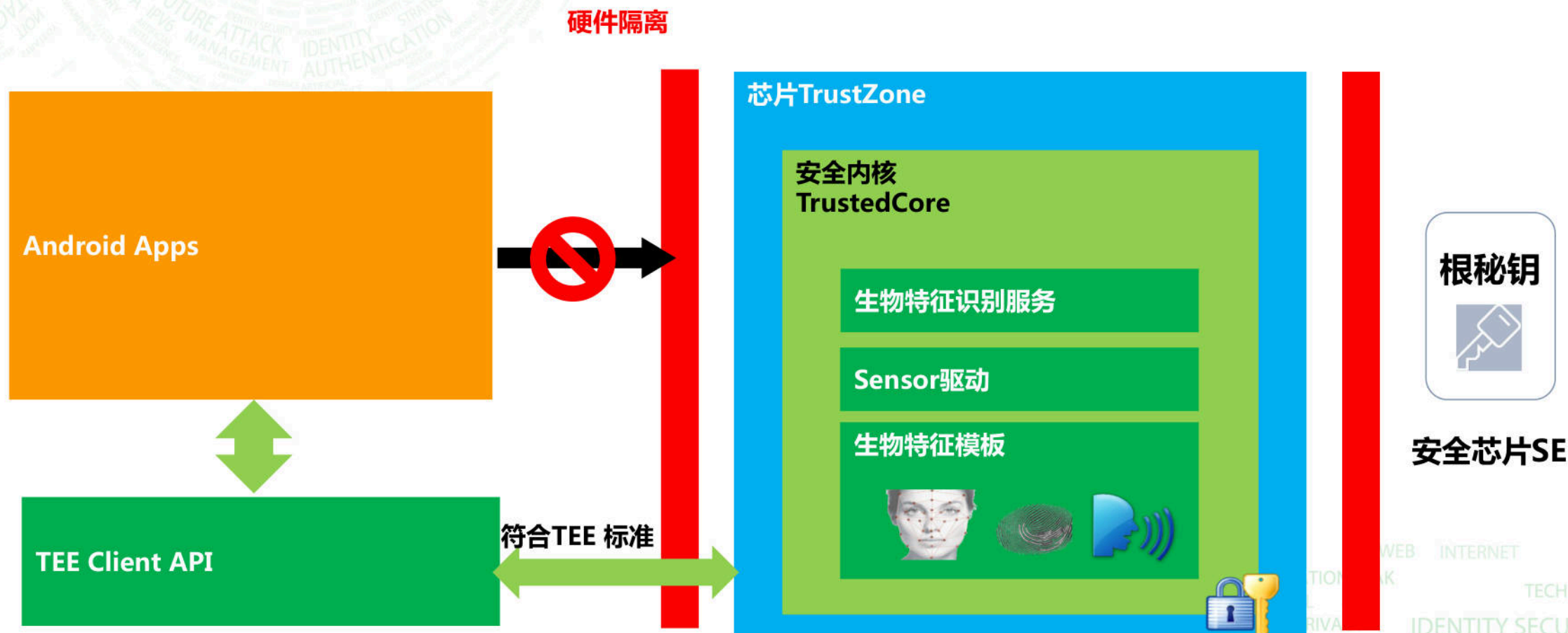
- 场景1：小额免密等场景，安全风险大，需要新的**体验好的方式来认证人的身份**，提升风控能力，增强安全性；
- 场景2、支付账号被盗/撞库攻击/银行卡盗刷等造成损失，需要新的**认证方式**来提升防范能力，减少损失；

- 场景3、当前应用登录都是一次性认证的，自动登录的应用长期不校验，安全隐患大，需要**体验好且能持续的认证方式**，增强安全性；
- 场景4、对于使用应用锁进行隐私保护的应用，需要经常认证，体验下降，需要**体验好的认证方式**，提升使用体验；

当前的单一身份认证，在小额免密、应用锁等场景体验不好或存安全风险，需要引入持续的行为身份认证、融合身份技术来提升使用体验、增强安全性。

ZERO TRUST SECURITY

生物特征数据不可撤销，需可信执行环境确保数据安全

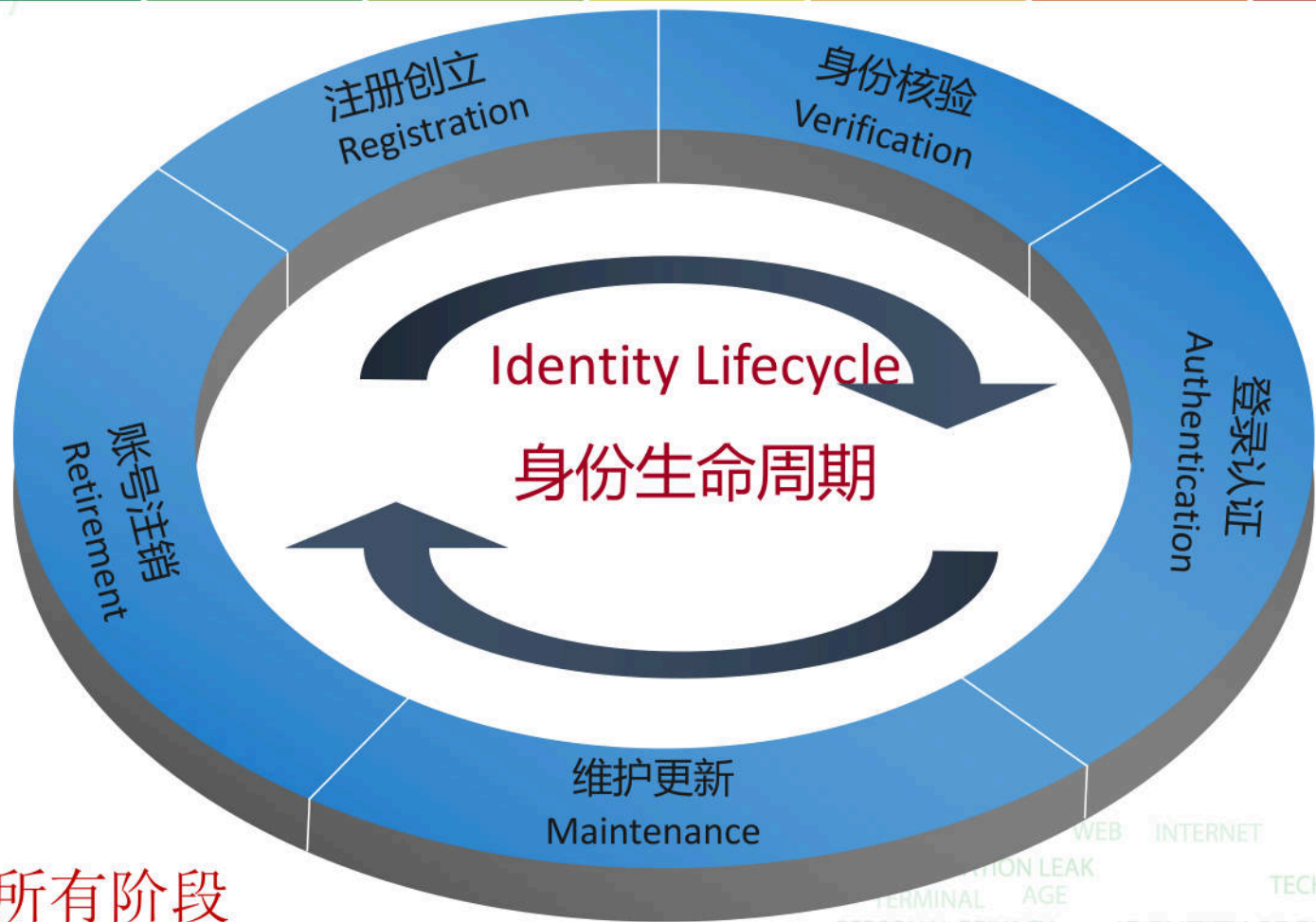


可信执行环境架构

可信唯一

信任根源：人的身份+权威签发机构
唯一标识：网络账号，数字证书等
核验方法：面签，推导等

认证方法	例子
What you know 所知	密码
What you have 所有	令牌
What you are 所是	指纹
What you behave 所为	手势



厂商仅负责所有阶段

网络可信身份战略是国家战略，也应该是每个企业的战略

身份生态体系7大原则

1. **安全** Security, by making it more difficult for adversaries to compromise online transactions;
2. **高效** Efficiency based on convenience for individuals who may choose to manage fewer passwords or accounts than they do today, and for the private sector, which stands to benefit from a reduction in paper-based and account management processes;
3. **便捷** Ease-of-use by automating identity solutions whenever possible and basing them on technology that is easy to operate with minimal training;
4. **可信** Confidence that digital identities are adequately protected, thereby increasing the use of the Internet for various types of online transactions;
5. **私密** Increased privacy for individuals, who rely on their data being handled responsibly and who are routinely informed about those who are collecting their data and the purposes for which it is being used;
6. **选择** Greater choice, as identity credentials and devices are offered by providers using interoperable platforms;
7. **创新** Opportunities for innovation, as service providers develop or expand the services offered online, particularly those services that are inherently higher in risk;

网络身份认证：美国国家可信身份顶层架构

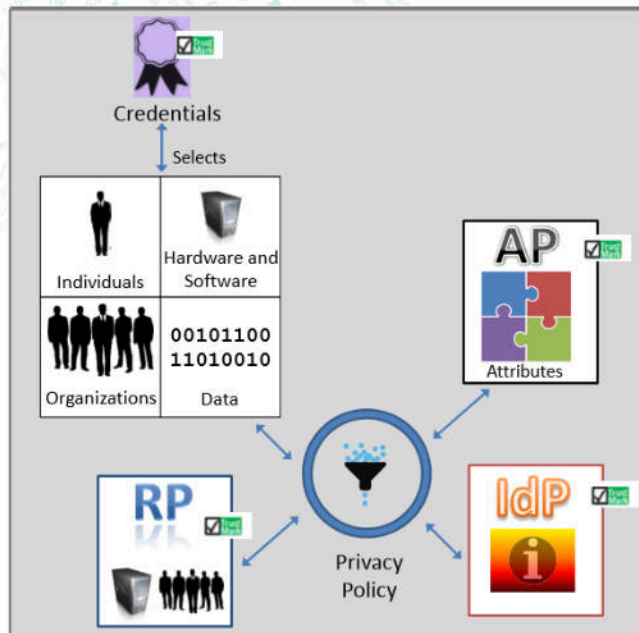


Figure 1: Execution Layer

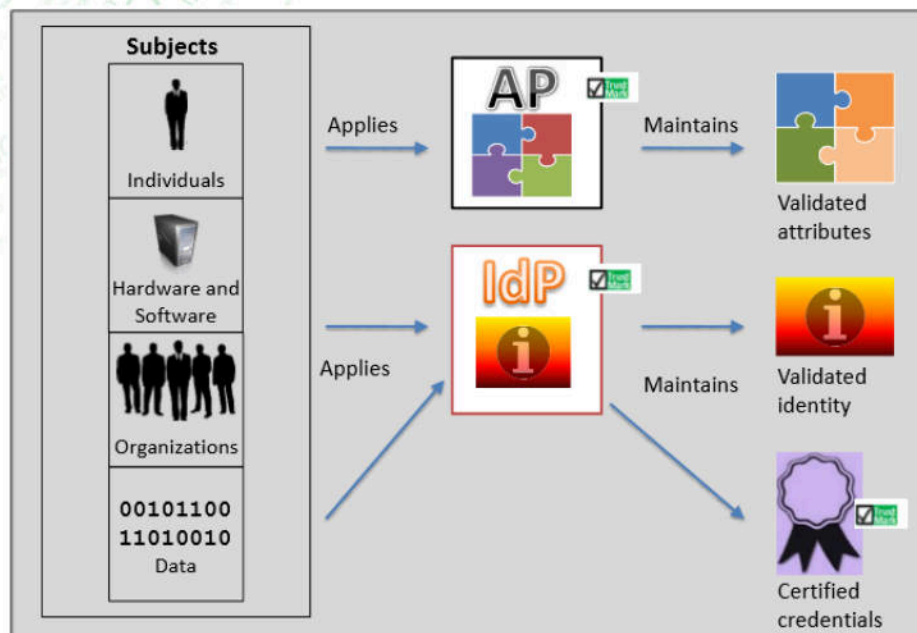


Figure 2: Management Layer

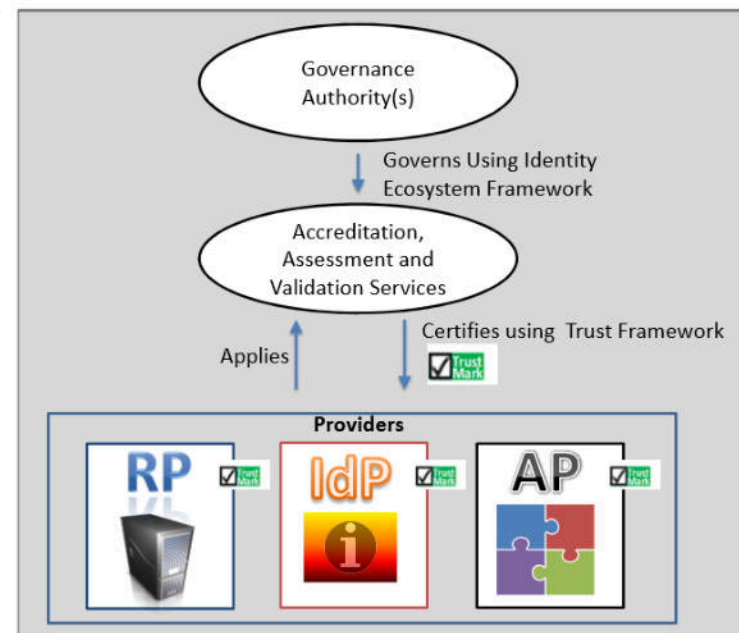


Figure 3: Governance Layer

身份生态体系5大特征

- Individuals and organizations choose the providers they use and the way they conduct transactions securely.
- Participants can trust one another and have confidence that their transactions are secure.
- Individuals can conduct transactions online with multiple organizations without sacrificing privacy.
- Identity solutions are simple for individuals to use and efficient for providers.
- Identity solutions are scalable and evolve over time.

网络身份认证：中国国家战略与顶层架构？

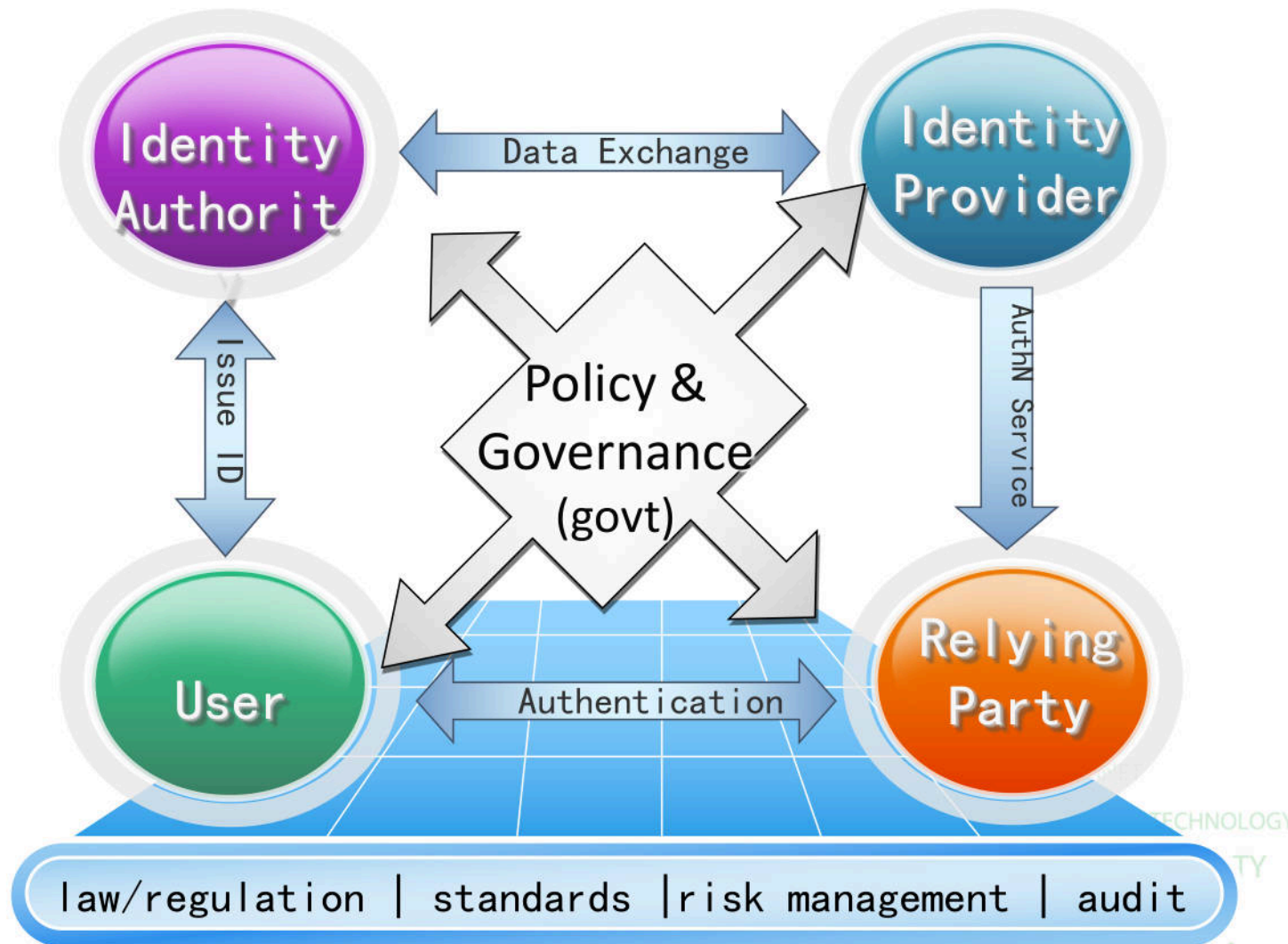
中国实名制：2012年全国人大法案加强网络信息保护的決定

中华人民共和国公安部

公科信〔2017〕209号

关于印发《“互联网+可信身份认证平台”应用实施指南（试行）》的通知

各省、自治区、直辖市公安厅、局，新疆生产建设兵团公安局：
现将《“互联网+可信身份认证平台”应用实施指南（试行）》印发给你们，请结合本地实际，组织开展应用。各地在工作中遇到的问题，请及时报部“互联网+可信身份认证平台”领导小组办公室。



来源：公安部一所

消费者数字身份十大威胁与挑战



ISC 互联网安全大会



360 互联网安全中心

1. 服务提供商之间数字身份零散、缺乏便捷性，用户体验不友好。
2. 数字身份被用户重用，易受撞库攻击，安全风险大。
3. 多种攻击手段使数字身份被仿冒、盗用风险高。
4. 数字身份全生命周期中用户敏感数据易被泄露。
5. 法律法规要求的数字身份的实名制管理与核验困难。
6. 数字身份在线下使用时如何保证安全。
7. 数字身份丢失时，如何保证服务不会间断。
8. 隐私保护与基于大数据的智能化增值服务的冲突。
9. 如何满足数字身份的匿名和实名需求。
10. 数字身份认证中的生物特征具有唯一性，如何保证安全。

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

各种服务自建账号体系，管理乱象横生，灾难性安全事件频发



年份	涉事服务商	事件简述	泄露用户量
2017.11	Uber 优步	两名黑客盗取了乘客的姓名、电子邮件和电话号码	5700万
2017.10/2013.8	Yahoo 雅虎	网络攻击致使用户账号信息泄露	30亿（全部）
2017.9	Equifax	遭到黑客袭击，大约1.43亿名用户数据泄露，黑客窃取的信息包括社保号码、生日、地址、信用卡信息等	1.43亿
2017.10	Dracore Data Sciences	南非史上规模最大的数据泄露事件，连总统祖马和多位部长都未能幸免	3160万
2016.4	土耳其政府	重大数据泄露事件直接导致个人信息遭到威胁，其中包括姓名、身份证号、父母名字、住址等敏感信息	5000万
2016.5	美国Tumblr	轻博客网站Tumblr邮箱账号密码惨遭泄露	6500万
2016.5	LinkedIn领英	黑客组织在黑市上以5比特币的售价公开销售领英用户登录信息	1.67亿
2016.9	MySpace	黑客已经拿到了用户账号密码以6个比特币的价格公开出售。	3.6亿
2016.10	网易	网易用户数据库泄露信息包括用户名、密码、密码密保信息、登录ip以及用户生日等	1亿
2016.10	Adult Friend Finder	黑客收集了数据库的姓名，邮箱，口令	4.12亿

ZERO TRUST SECURITY

消费者统一网络账号：市场与标准状况



ISC 互联网安全大会



360 互联网安全中心

IdP	帐号服务	用户数量
脸谱	Facebook ID	20亿
谷歌	Gmail账号	9亿
苹果	Apple ID	6亿
微软	Microsoft Account	4亿
腾讯	微信ID	10亿
阿里	支付宝账号	5亿
微博	微博账号	4亿
华为	华为账号	3亿

	IFAA	SOTER	FIDO
标准类别	联盟标准	企业标准	联盟标准
接入方式及周期	提供参考实现源码，2015年9月提供自助接入平台，厂商接入周期在1~2周。	提供参考实现源码，2017年8月提供自助接入平台，厂商接入周期在2~4周。	二进制库形式提供，无自助接入平台，厂商接入周期在2~4周。
支持的手机型号	覆盖绝大多数国内发售的手机品牌，220多款机型。	覆盖30家厂商、100+款机型	覆盖少量手机品牌，15-20款机型
检测机构	授权实验室	企业自检	授权实验室
行业覆盖	银行、第三方支付、电商等行业（支付宝、淘宝、浦发、苏宁易购、上海CA等）。	刚通过技术开源，开放给外部APP	银行、第三方支付等行业（翼支付、京东钱包、中国银行、工商银行等）。
联盟会员数	128家	无	350家，国内26家
覆盖用户数	5亿+	2亿+	无数据
支持的身份认证类型	指纹、人脸和虹膜等多种身份认证形式。	指纹	指纹、人脸和虹膜等多种身份认证形式

统一管理数字身份和实体身份，以用户为中心，移动设备为入口

业务驱动力

- 账户密码太多，不便于使用
- 账户密码安全性不够
- 多拷贝导致需要信任太多节点

OpenID出现

技术驱动

- 只能移动设备的普及
- 集中化导致泄露影响面大
- 商业驱动
- 掌握在线服务入口

FIDO联盟成立

技术驱动力

- 区块链技术成熟，解决了之前无法解问题

业务驱动力

- 支付等业务需要

商业驱动力

- 账务各种线上线下服务入口，绑定用户到移动设备

2005 第一代

2013 第二代

2018 第三代

Silo

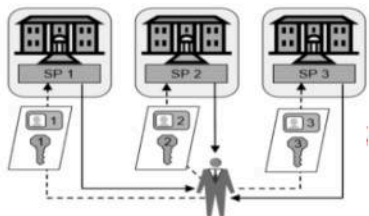
Federation

用户为中心

数字身份与实体身份相融合

断代特征

- 多账户，多密码
- 用户身份信息多拷贝
- 安全性取决于最弱节点



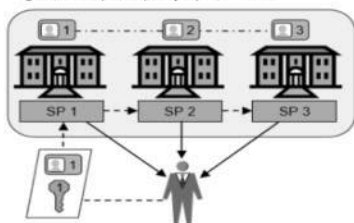
Google



2005年之前几乎所有的服务提供商

断代特征

- 单账户，单密码
- 用户身份信息单拷贝
- 移动设备和生物信息作为多因子
- 安全性取决于IDP



Google

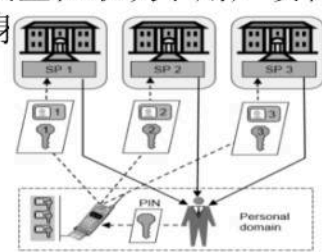
facebook



2005年之后大部分的服务提供商

断代特征

- 单账户，单密码
- 用户自己控制身份信息，采用移动设备和生物信息保护
- 安全性取决于用户设备
- 身



fido alliance

IFAA

互联网金融身份认证联盟

SOTER



三大联盟

断代特征

- 在线身份和实体身份融合
- 自主控制实体身份信息
- 区块链成为关键技术



尚无成熟产品，一些身份提供商在尝试

INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
TECHNOLOGY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

实体身份认证发展趋势：数字化，与数字身份融合，自主管理，政府主导信任平台



业务驱动力

- 管理不便，比如状态改变只能依赖有效期，难吊销
- 防伪难

业务驱动力

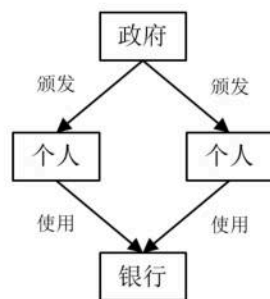
- 无特殊设备情况下，难验证真伪
- 互联网在线使用不便

身份证自身特点

- 纸质非电子化
 - 身份证用户持有，**自主管理**
- ## 身份管理特点
- 政府是唯一的身份提供商



一代身份证



身份证自身特点

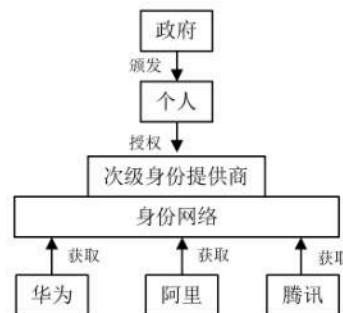
- **数字化**但仍不适于互联网在线使用
- 用户持有，**自主管理身份**

身份管理特点

- 政府仍是主要身份提供商
- 非政府身份提供商作为次级身份提供商，对外提供身份服务



二代身份证



Shocard: 次级身份提供商

身份证明自身特点

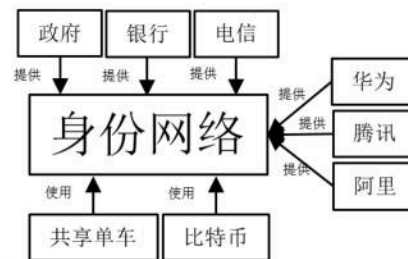
- 加入公私钥对，**数字化加深**，远程使用成为可能，从而与**互联网身份融合**

身份管理特点

- 身份信息仍由用户**自主管理**
- **国家主导信任平台**发布身份信息
- 除政府外，银行，电信等更多的身份提供商加入网络
- 任何身份提供商都可以提供和使用用户身份
- 身份信息可在多组织间共享



爱沙尼亚身份证



英国政府



爱沙尼亚政府



美国政府



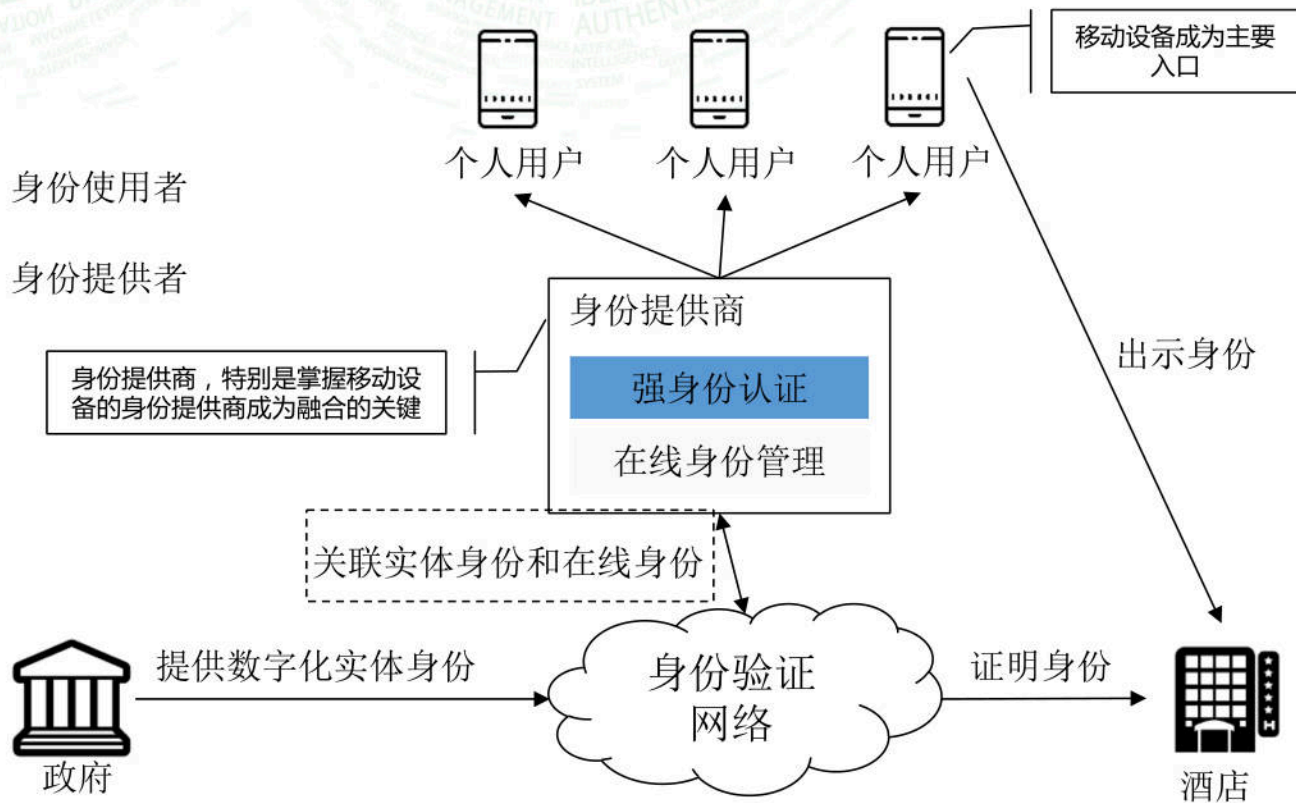
印度政府

ZERO TRUST SECURITY

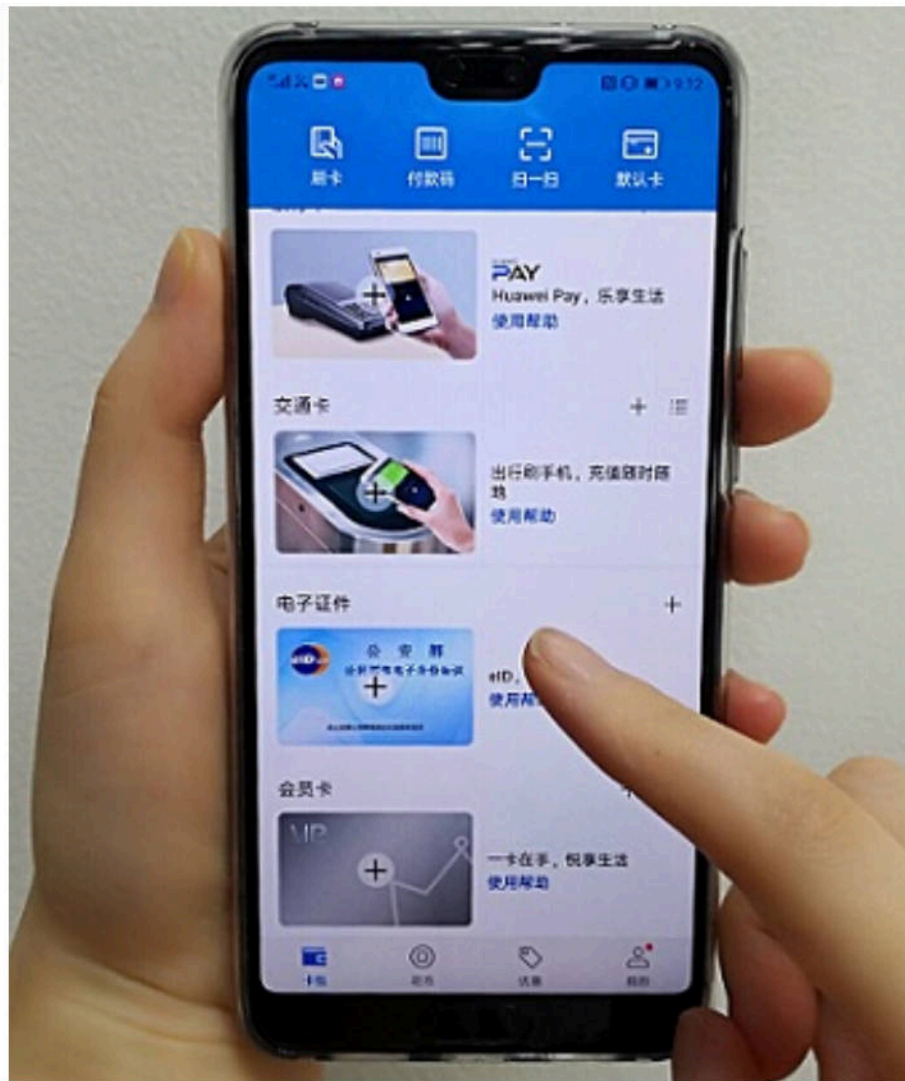
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

华为实践-实体身份与数字身份相融合解决方案

实体身份和数字身份如何融合



* 箭头表示数据流动方向



区块链技术的成熟促进了两种身份的融合，可以使身份认证技术向新一代发展

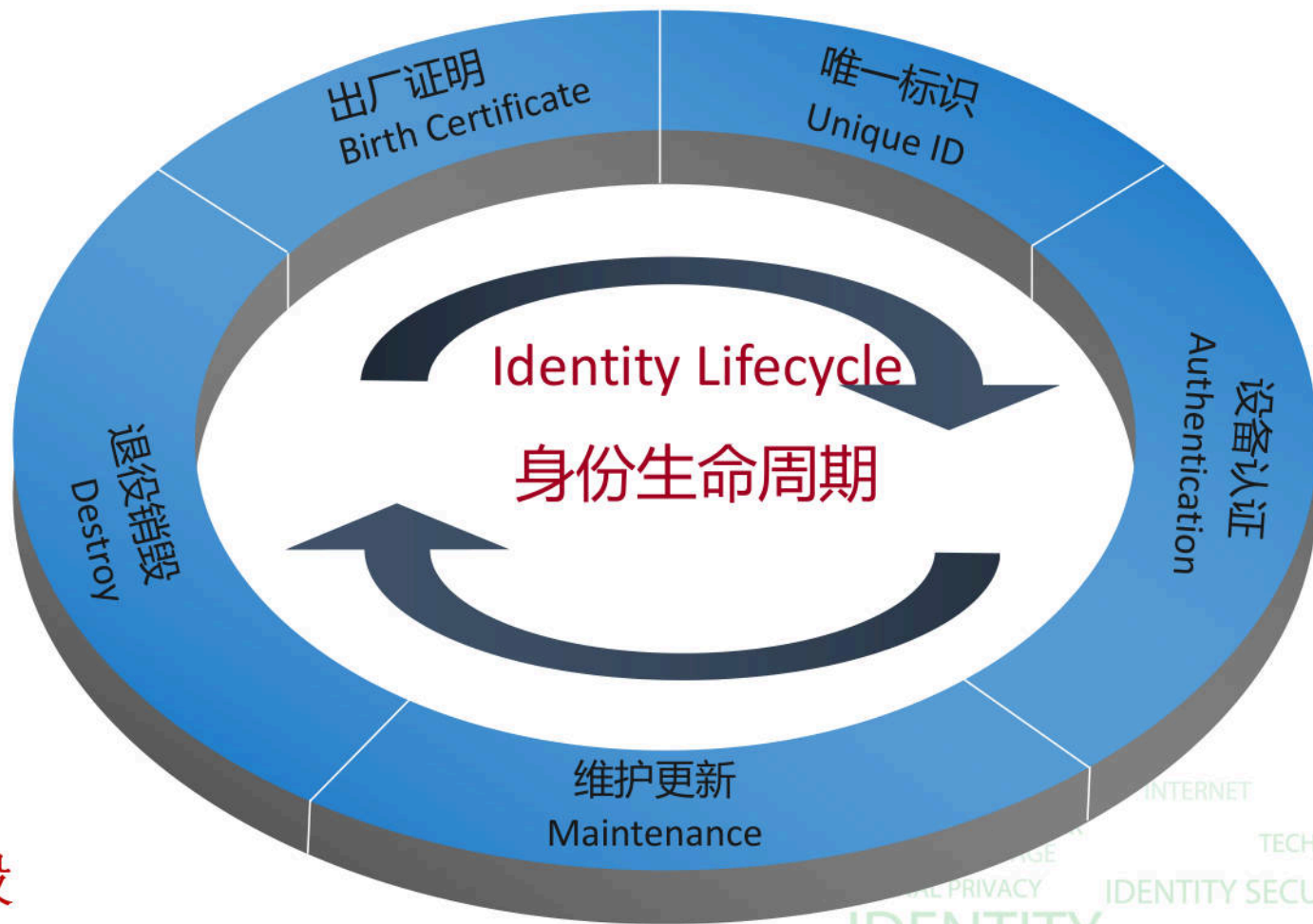
可信唯一

信任根源：硬件信任根+生产厂商

唯一标识：安全芯片，私钥，密码学技术所产生证书等

认证方式：需要双向或分布式多向认证协议（PSK，PKI，CPK，区块链等）

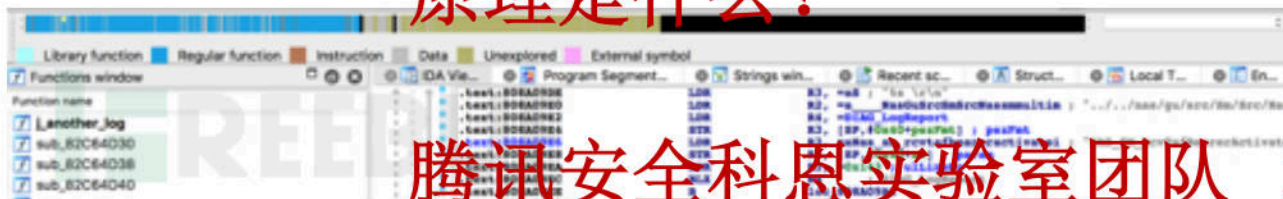
厂商负责所有阶段



设备ID安全要解决的问题 – 案例



有个问题不解，手机为什么会连上那个设备的？
原理是什么？



```
byte_pos = 0;
/* Initial copy of raw content ... omitted */
for (index = 1; index < 20; index++) {
    memcpy_s(parsedDst + byte_pos, someControlledLen,
            cmInput + someControlledOffset, someControlledLen);
    byte_pos += someControlledLen;
}
```

Table 3.4-1. SMS Transport Layer Messages

Message Type	base station -> mobile station	mobile station -> base station	SMS_MSG_TYPE
SMS Point-to-Point	X	X	'00000000'
SMS Broadcast	X		'00000001'
SMS Acknowledge		X	'00000010'
All other values are reserved.			

腾讯安全科恩实验室团队 2018-08-17 回复

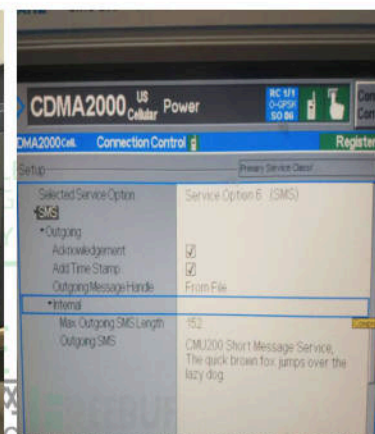
Table 4.5-1. Bearer Data Subparameter Identifiers

Subparameter	SUBPARAMETER_ID Value
Message Identifier	'00000000'
User Data	'00000001'
User Response Code	'00000010'
Message Center Time Stamp	'00000011'
Validity Period - Absolute	'00000100'
Validity Period - Relative	'00000101'
Deferred Delivery Time - Absolute	'00000110'
Deferred Delivery Time - Relative	'00000111'
Priority Indicator	'00001000'
Privacy Indicator	'00001001'
Reply Option	'00001010'
Number of Messages	'00001011'
Alert on Message Delivery	'00001100'
Language Indicator	'00001101'
Call-Back Number	'00001110'
Message Display Mode	'00001111'
Multiple Encoding User Data	'00010000'
Message Deposit Index	'00010001'
Service Category Program Data	'00010010'
Service Category Program Results	'00010011'

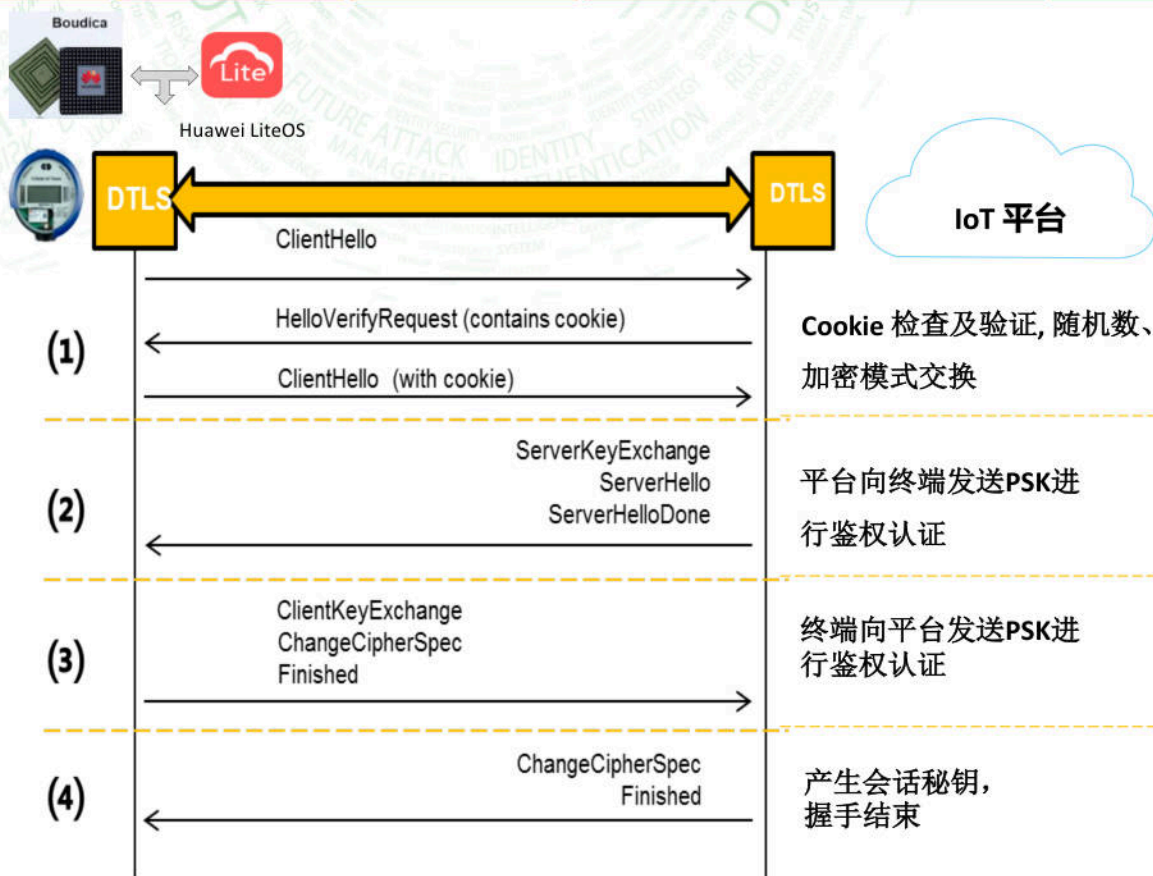
由于2G CDMA没有做双向认证，通过屏蔽箱屏蔽周围的电磁信号后，手机会直接连接到设备上。



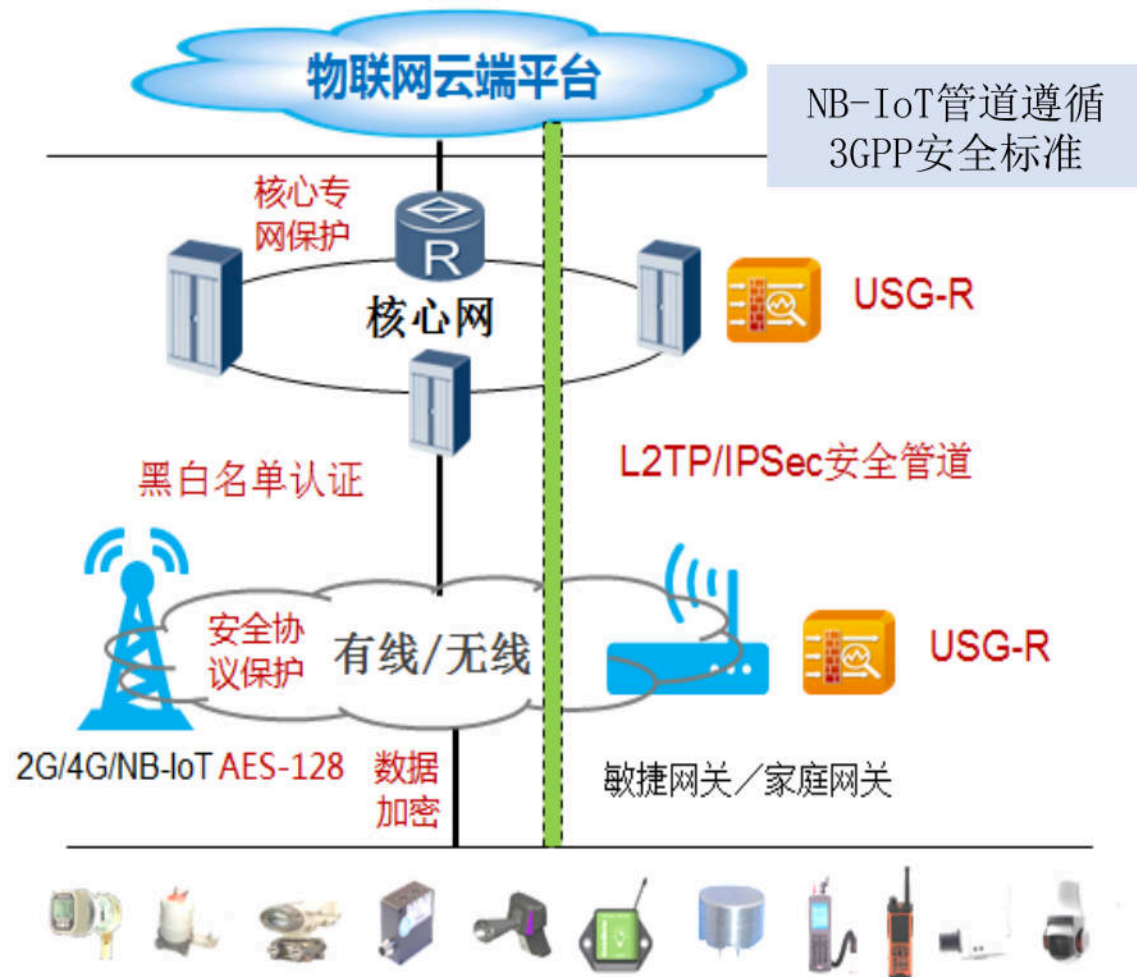
```
while (v6 < 4 * MEMORY[0xF0040000]);
if (MEMORY[0xF0040000] != v6) {
    printf("<FLASH> ", a2, a3, a4, a5, a6, &unk_620000);
    v7 = printf("Bad checksum! Expected: 0x08X, computed: 0x08X\n", MEMORY[0xF0040000], v6);
    goto LABEL_8;
}
return 0;
```



设备安全技术案例：双向认证识别



- 采用PSK (Pre shared key) 认证，服务端为终端预置密钥，极大地简化了密钥交换的工作，快速完成信息交换，适合计算资源十分有限的设备





ISC 互联网安全大会



360互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China